Admin Panel API: Endpoints for Testing

Base URL (local): http://localhost:8000. Interactive docs: http://localhost:8000/docs

All endpoints except login need the header `Authorization: Bearer <token>`.

How to start the backend

```
cd backend
export JWT_SECRET=any-long-random-string
export SYSADMIN_EMAIL=sysadmin@example.com
export SYSADMIN_PASSWORD=ChangeMe123
.venv/bin/uvicorn app.main:app --reload
```

The first sysAdmin is created from SYSADMIN_EMAIL and SYSADMIN_PASSWORD on first start, when no users exist.

Test accounts to create

Log in as the sysAdmin, create two companies (A and B), then create in each: one admin and one user. Use these four accounts plus the sysAdmin for the cases below.

Roles

sysAdmin = all companies. admin = own company. user = no admin access.

Endpoints

#	Method	Path	Who can call	Purpose
1	POST	/auth/login	anyone	Get a token
2	GET	/auth/me	any logged-in user	Current user
2a	POST	/auth/signup	anyone	Create a company and its first admin, returns a token
2b	POST	/auth/forgot-password	anyone	Request a reset link (same reply for unknown emails)
2c	POST	/auth/reset-password	anyone with a reset token	Set a new password, token works once, 15 minutes
3	GET	/admin/companies	sysAdmin	List companies
4	POST	/admin/companies	sysAdmin	Create company
5	PATCH	/admin/companies/{id}	sysAdmin	Rename, deactivate, restore
6	GET	/admin/users	admin, sysAdmin	List users (admin: own company)
7	POST	/admin/users	admin, sysAdmin	Create user
8	GET	/admin/users/{id}	admin, sysAdmin	Get one user
9	PATCH	/admin/users/{id}	admin, sysAdmin	Edit name, password, role, active
10	GET	/admin/audit-logs	admin, sysAdmin	Audit trail (admin: own company)

CONFIDENTIAL

Request and response details

1. POST /AUTH/LOGIN

Body: `{"email": "a@x.com", "password": "secret123"}` 200: `{"access_token": "...", "token_type": "bearer"}` 401: `{"detail": "Unauthorized access"}` (wrong password, unknown email, inactive user or company)

2. GET /AUTH/ME

200: `{"id", "email", "name", "role", "company_id", "active"}`

2A. POST /AUTH/SIGNUP

Body: `{"company_name", "name", "email", "password" (min 8)}`. 201 returns a token, the user is the admin of the new company. 409 for an existing email or company name.

2B. POST /AUTH/FORGOT-PASSWORD

Body: `{"email"}`. Always 200 “If the account exists, a reset link has been sent.” There is no mail server yet: the token is printed in the backend log as `PASSWORD RESET for <email>: token=...`. Open `http://localhost:5173/?reset=<token>`.

2C. POST /AUTH/RESET-PASSWORD

Body: `{"token", "password" (min 8)}`. 200 on success. 400 “This reset link is invalid or has expired.” for a bad, expired or already used token. A reset token is rejected as a login token (401 on /auth/me).

3. GET /ADMIN/COMPANIES

200: list of `{"id", "name", "active"}`

4. POST /ADMIN/COMPANIES

Body: `{"name": "Acme"}`. 201 returns the company. 409 if the name exists.

CONFIDENTIAL

5. PATCH /ADMIN/COMPANIES/{ID}

Body, any of: `{"name": "New", "active": false}`. 404 if the id does not exist.

6. GET /ADMIN/USERS

Optional query: `company_id` (sysAdmin only, ignored for admin).

7. POST /ADMIN/USERS

Body: `{"email", "name", "password" (min 8), "role": "user|admin|sysAdmin", "company_id"}`

- sysAdmin must send company_id unless creating a sysAdmin.
- admin: company_id is ignored, user is created in the admin's own company. admin cannot create sysAdmin (403).
- 409 for a duplicate email, or for an inactive company ("This company is inactive. Restore it before adding users.").
- 422 when no valid company is given.

8. GET /ADMIN/USERS/{ID}

404 when the user does not exist or belongs to another company (for admin).

9. PATCH /ADMIN/USERS/{ID}

Body, any of: `{"name", "password", "role": "admin|user", "active": true|false}`

- 400 when changing your own role or status.
- 400 when changing a sysAdmin's role.
- 409 "A company needs at least one active admin." when removing the last active admin.

10. GET /ADMIN/AUDIT-LOGS

Query: `action` (exact match, e.g. user.create), `company_id` (sysAdmin only), `limit` (1-200, default 50), `offset`. 200: list of `{"id", "actor_id", "actor_email", "company_id", "action", "target_type", "target_id", "meta",`

CONFIDENTIAL

`"created_at"}`, newest first.

Test cases

SIGNUP AND PASSWORD RESET

27. Sign up with a new company: lands in the panel as admin, with Users and Audit log only. Row auth.signup appears.
28. Sign up again with the same email or company name: expect 409.
29. Forgot password with a known and an unknown email: same message both times. Only the known one writes auth.reset_requested.
30. Use the reset link, set a new password, sign in with it. Using the same link again: expect 400.
31. Paste a reset token as a Bearer token on /auth/me: expect 401.

AUTHENTICATION

1. Call any /admin endpoint with no token: expect 401.
2. Call with a garbage token: expect 401.
3. Log in with a wrong password: expect 401 “Unauthorized access”, and an auth.login_failed row in the audit log.
4. Deactivate a user, then use that user’s old token on /auth/me: expect 401.
5. Deactivate a company, then log in as its user: expect 401.

ROLE RESTRICTIONS

6. As user: call endpoints 3 to 10: expect 403 on every one.
7. As admin: call endpoints 3, 4, 5: expect 403.
8. As sysAdmin: endpoints 3 to 10 work.

COMPANY ISOLATION

9. As admin of A: GET /admin/users returns only company A users, and no sysAdmin.
10. As admin of A: GET or PATCH a user id from company B: expect 404.
11. As admin of A: GET /admin/users/{sysAdmin id}: expect 404.
12. As admin of A: create a user with company_id of B: user is created in A.

CONFIDENTIAL

13. As admin of A: GET /admin/audit-logs shows only company A rows.
14. As sysAdmin: list users with and without company_id, and audit logs with company_id: both companies are visible.

ADMIN RULES

15. As admin: create a sysAdmin: expect 403.
16. Deactivate or demote the only active admin of a company: expect 409.
17. Deactivate or change the role of your own account: expect 400.
18. Create a user in an inactive company: expect 409.
19. Create a user with an existing email: expect 409. Password shorter than 8: expect 422.

AUDIT LOG

20. After each of these, exactly one new row appears with the right action, actor, target and company: create company, deactivate company, create user, change role, deactivate user, restore user, edit name.
21. The audit log has no edit or delete endpoint: PUT, PATCH and DELETE on /admin/audit-logs return 405.
22. Filter by action=user.create returns only those rows.

ADMIN UI (HTTP://LOCALHOST:5173)

23. Sign in as sysAdmin: Users, Companies and Audit log tabs are visible.
24. Sign in as admin: Users and Audit log only, company dropdown is not shown when adding a user.
25. Sign in as user: “Your account has no admin access” message.
26. Your own row and sysAdmin rows show no action buttons.

CONFIDENTIAL